A Comprehensive Security Assessment of OWASP Juice Shop: An OWASP-Aligned Penetration Testing Analysis

Target: OWASP Juice Shop
Prepared by: Sehba Ashraf Bangalath
Date: April 2026

1. Executive Summary

This penetration test evaluated the security posture of the OWASP Juice Shop web application using industry-standard methodologies derived from the OWASP Testing Guide. The assessment focused on identifying vulnerabilities across the application's backend services, client-side components, and deployment configuration.

The evaluation uncovered several significant weaknesses, including backend information disclosure, outdated and vulnerable JavaScript dependencies, misconfigured directories, and publicly accessible resources. These issues collectively expose the application to realistic attack vectors and align with multiple OWASP Top 10 categories, such as Security Misconfiguration, Sensitive Data Exposure, and the Use of Components with Known Vulnerabilities.

The findings highlight systemic gaps in secure development practices and underscore the importance of robust configuration management, dependency governance, and secure coding principles. Addressing these weaknesses will substantially reduce the application's attack surface and enhance its resilience against contemporary web-based threats.

2. Scope

In Scope

- Web application hosted on dynamically assigned lab IP
- Unauthenticated testing
- Reconnaissance and enumeration
- Automated and manual vulnerability assessment
- OWASP Testing Guide v4 methodology

Out of Scope

- Denial-of-Service (DoS) attacks
- Authentication bypass attempts
- Data modification or extraction
- Exploitation beyond safe proof-of-concept

3. Methodology

The assessment followed a structured, academically recognised methodology based on the OWASP Testing Guide v4. The process included:

- **Information Gathering:** Identifying exposed services and technologies
- **Configuration and Deployment Testing:** Assessing server and application configuration
- **Error Handling and Input Validation Testing:** Observing backend behaviour under unexpected input
- **Client-Side Testing:** Reviewing exposed assets and outdated libraries
- **API and Endpoint Testing:** Evaluating responses from accessible routes
- **Automated Scanning:** Using industry tools (Nmap, Nikto, Gobuster, httpx) to identify weaknesses

This multi-layered approach ensures comprehensive coverage of the application's attack surface.

4. Reconnaissance

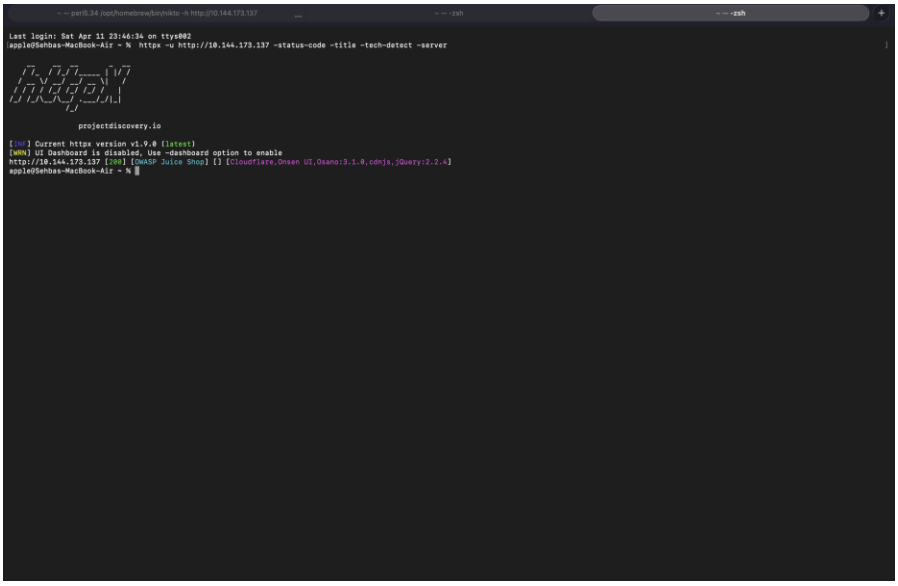
4.1 Nmap Scan

```
apple@Sehbas-MacBook-Air ~ % nmap -Pn -sV 10.144.173.137

Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-11 23:33 +1200
Nmap scan report for 10.144.173.137
Host is up (0.16s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.11 (Ubuntu Linux; protocol 2.0)
80/tcp open  http
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port80-TCP:V=7.99%I=7%D=4/11%Time=69DA3181%P=arm-apple-darwin25.3.0%r(G
SF:etRequest,3098,"HTTP/1\.1\x20200\x20OK\r\nAccess-Control-Allow-Origin:\
SF:x20\*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SAME
SF:ORIGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/#/j
SF:obs\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-age=
SF:0\r\nLast-Modified:\x20Sat,\x2011\x20Apr\x202026\x2011:26:25\x20GMT\r\n
SF:ETag:\x20W/\"138f6-19d7c4b07af\"\r\nContent-Type:\x20text/html;\x20char
SF:set=UTF-8\r\nContent-Length:\x2088118\r\nVary:\x20Accept-Encoding\r\nDa
SF:te:\x20Sat,\x2011\x20Apr\x202026\x2011:34:08\x20GMT\r\nConnection:\x20c
SF:lose\r\n\r\n<!--\n\x20\*\x20Copyright\x20(c)\x202014-2026\x20Bjoer
SF:n\x20Kimminich\x20&\x20the\x20OWASP\x20Juice\x20Shop\x20contributors\.\
SF:n\x20\*\x20-\x20SPDX-License-Identifier:\x20MIT\n\x20\*\x20-->\n\n<!doctype
SF:\x20html\n\n<html\x20lang=\"en\"\x20data-beasties-container>\n<head>\n\x
SF:20\x20<meta\x20charset=\"utf-8\">\n\x20\x20<title>OWASP\x20Juice\x20Sho
SF:p</title>\n\x20\x20<meta\x20name=\"description\"\x20content=\"Probably\
SF:x20the\x20most\x20modern\x20and\x20sophisticated\x20insecure\x20web\x20
SF:application\">\n\x20\x20<meta\x20name=\"viewport\"\x20content=\"width=d
SF:evice-width,\x20initial-scale=1\">\n\x20\x20<link\x20id=\"favicon\"\x20
SF:rel=\"icon\"\x20")%r(HTTPOptions,EA,"HTTP/1\.1\x20404\x20Nu\x20Content\
SF:r\nAccess-Control-Allow-Origin:\x20\*\r\nAccess-Control-Allow-Methods:\
SF:x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Access-Control-Request-He
SF:aders\r\nContent-Length:\x200\r\nDate:\x20Sat,\x2011\x20Apr\x202026\x20
SF:11:34:09\x20GMT\r\nConnection:\x20close\r\n\r\n")%r(RTSPRequest,EA,"HTT
SF:P/1\.1\x20404\x20Nu\x20Content\r\nAccess-Control-Allow-Origin:\x20\*\r\
SF:nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVar
SF:y:\x20Access-Control-Request-Headers\r\nContent-Length:\x200\r\nDate:\x
SF:20Sat,\x2011\x20Apr\x202026\x2011:34:09\x20GMT\r\nConnection:\x20close\
SF:r\n\r\n")%r(X11Probe,2F,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nConnecti
SF:on:\x20close\r\n\r\n")%r(FourOhFourRequest,3098,"HTTP/1\.1\x20200\x20OK
SF:\r\nAccess-Control-Allow-Origin:\x20\*\r\nX-Content-Type-Options:\x20no
SF:sniff\r\nX-Frame-Options:\x20SAMEORIGIN\r\nFeature-Policy:\x20payment\x
SF:20'self'\r\nX-Recruiting:\x20/#/jobs\r\nAccept-Ranges:\x20bytes\r\nCach
SF:e-Control:\x20public,\x20max-age=0\r\nLast-Modified:\x20Sat,\x2011\x20A
SF:pr\x202026\x2011:26:25\x20GMT\r\nETag:\x20W/\"138f6-19d7c4b07af\"\r\nCo
SF:ntent-Type:\x20text/html;\x20charset=UTF-8\r\nContent-Length:\x2088118\
SF:r\nVary:\x20Accept-Encoding\r\nDate:\x20Sat,\x2011\x20Apr\x202026\x2011
SF::34:10\x20GMT\r\nConnection:\x20close\r\n\r\n<!--\n\x20\*\x20-\x20Copyrig
SF:ht\x20(c)\x202014-2026\x20Bjoern\x20Kimminich\x20&\x20the\x20OWASP\x2
SF:0Juice\x20Shop\x20contributors\.\n\x20\*\x20-\x20SPDX-License-Identifier:
SF:\x20MIT\n\x20\*\x20-->\n\n<!doctype\x20html>\n<html\x20lang=\"en\"\x20dat
SF:a-beasties-container>\n<head>\n\x20\x20<meta\x20charset=\"utf-8\">\n\x2
SF:0\x20<title>OWASP\x20Juice\x20Shop</title>\n\x20\x20<meta\x20name=\"des
SF:cription\"\x20content=\"Probably\x20the\x20most\x20modern\x20and\x20sop
SF:histicated\x20insecure\x20web\x20application\">\n\x20\x20<meta\x20name=
SF:\"viewport\"\x20content=\"width=device-width,\x20initial-scale=1\">\n\x
SF:20\x20<link\x20id=\"favicon\"\x20rel=\"icon\"\x20");
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 59.17 seconds
apple@Sehbas-MacBook-Air ~ %
```

The Nmap scan identified port 80 as open and serving HTTP traffic. This confirmed that the application was reachable and provided an initial entry point for further enumeration.

5. Fingerprinting

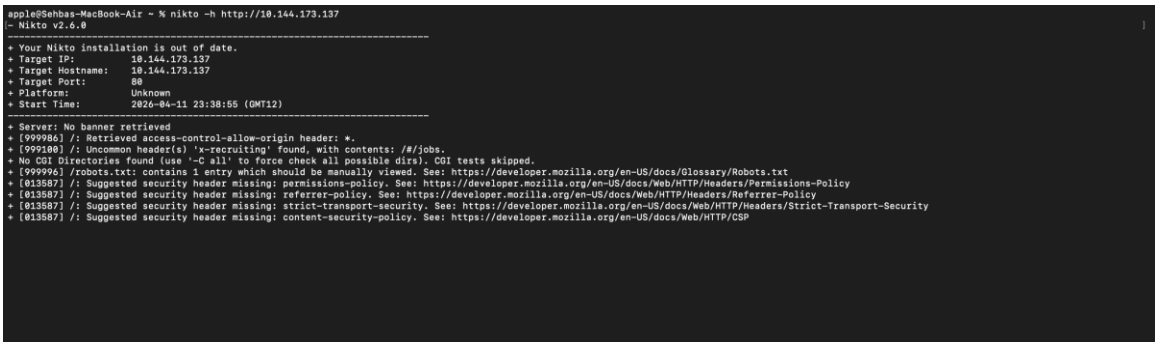
5.1 Technology Detection (httpx)



The fingerprinting process revealed the use of several client-side and server-side technologies, including Cloudflare, jQuery 2.2.4, Osano 3.1.0, Onsen UI, and Express.js. The presence of outdated libraries indicates potential exposure to known vulnerabilities.

6. Automated Scanning

6.1 Nikto Scan



Nikto identified multiple missing security headers, uncommon HTTP headers, and sensitive robots.txt entry. These findings indicate suboptimal server configuration and potential information disclosure.

7. Directory Enumeration

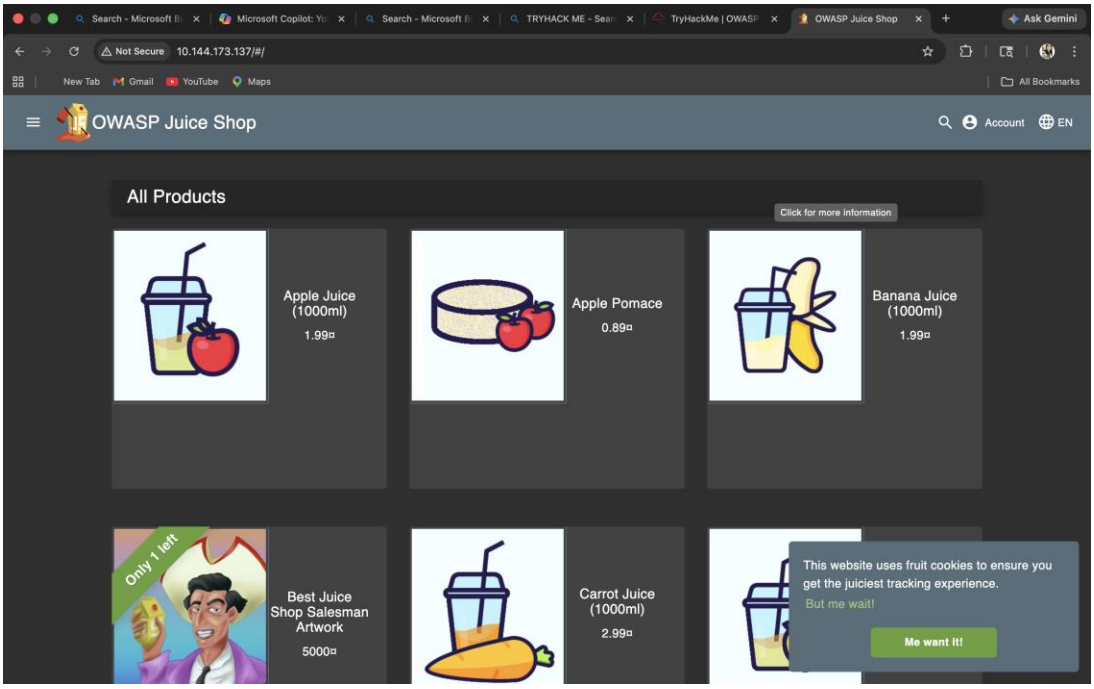
7.1 Gobuster Output

```
apple@Sehbas-MacBook-Air ~ % gobuster dir -u http://10.144.173.137 -w common.txt --exclude-length 80118

===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.144.173.137
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                common.txt
[+] Negative Status codes:   404
[+] Exclude Length:          80118
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
api                  (Status: 500) [Size: 3017]
apis                 (Status: 500) [Size: 3019]
assets               (Status: 301) [Size: 156] [--> /assets/]
ftp                  (Status: 200) [Size: 11308]
profile              (Status: 500) [Size: 1051]
promotion            (Status: 200) [Size: 6507]
redirect             (Status: 500) [Size: 3119]
restore              (Status: 500) [Size: 3025]
restaurants          (Status: 500) [Size: 3033]
rest                 (Status: 500) [Size: 3019]
restricted           (Status: 500) [Size: 3031]
restored             (Status: 500) [Size: 3027]
robots.txt           (Status: 200) [Size: 28]
Video                (Status: 200) [Size: 10075518]
video                (Status: 200) [Size: 10075518]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
apple@Sehbas-MacBook-Air ~ %
```

Gobuster enumeration revealed several accessible directories, including /api, /rest, /ftp, /assets, /promotion, /video, and /profile. The presence of these endpoints significantly expands the application's attack surface.

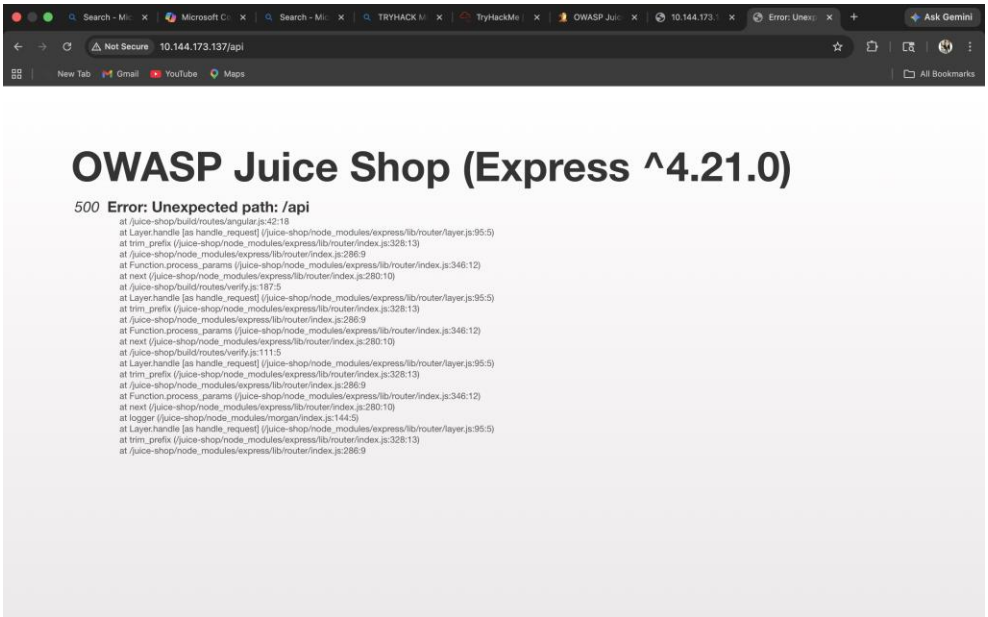
8. Manual Endpoint Testing

8.1 Homepage



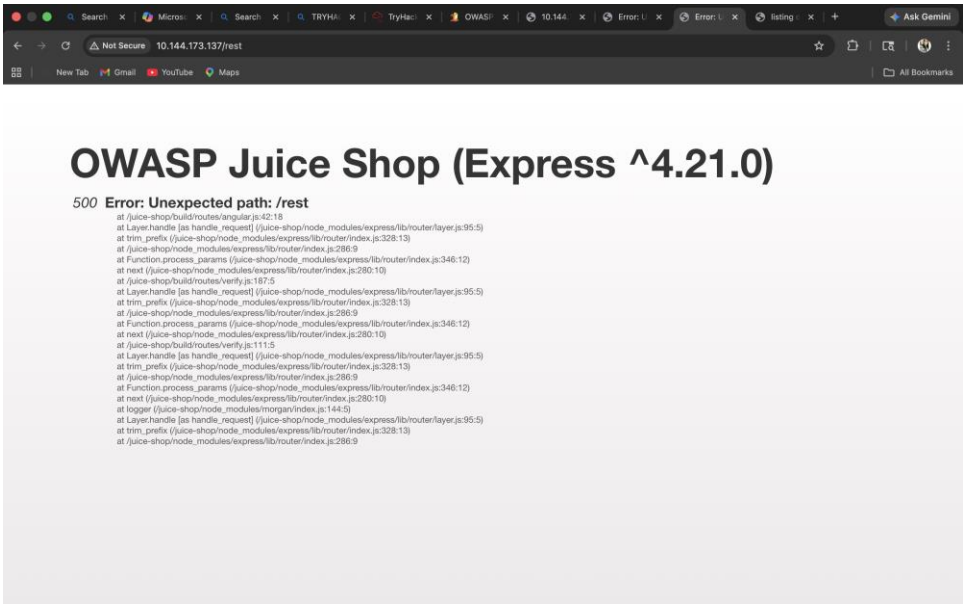
The homepage confirmed successful deployment and provided initial insight into the application's structure and client-side components.

8.2 /api Endpoint



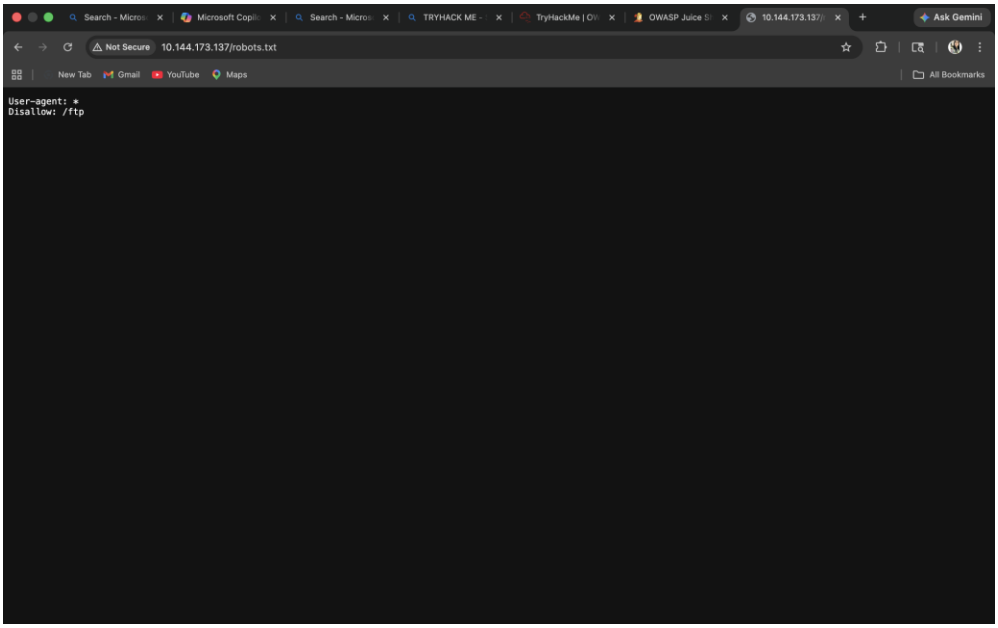
The /api endpoint returns a full Express.js stack trace, revealing internal file paths and backend logic. This behaviour constitutes a critical information disclosure of vulnerability.

8.3 /rest Endpoint



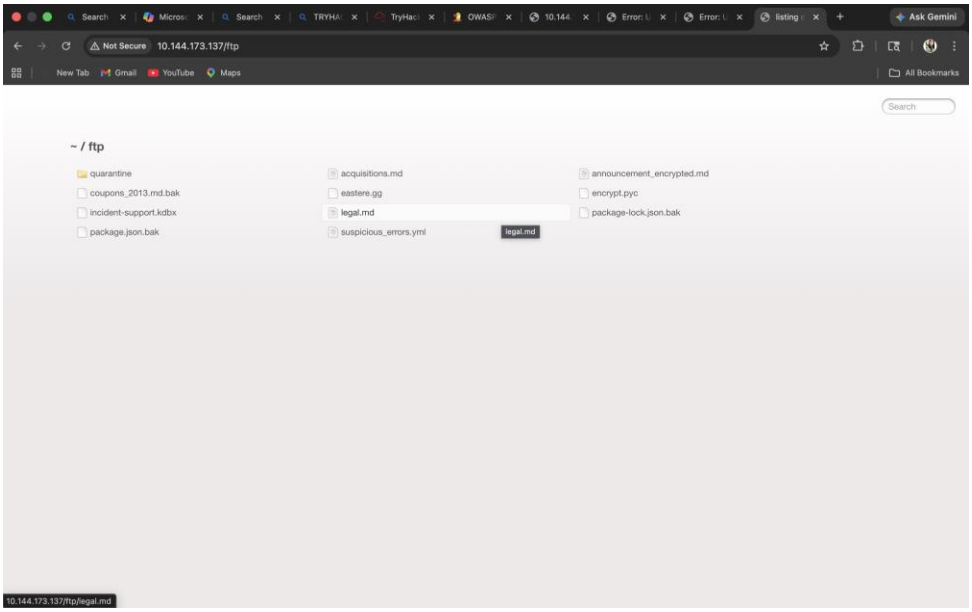
Similar to /api, the /rest endpoint exposed backend implementation details through verbose error messages, confirming inadequate error handling.

8.4 robots.txt



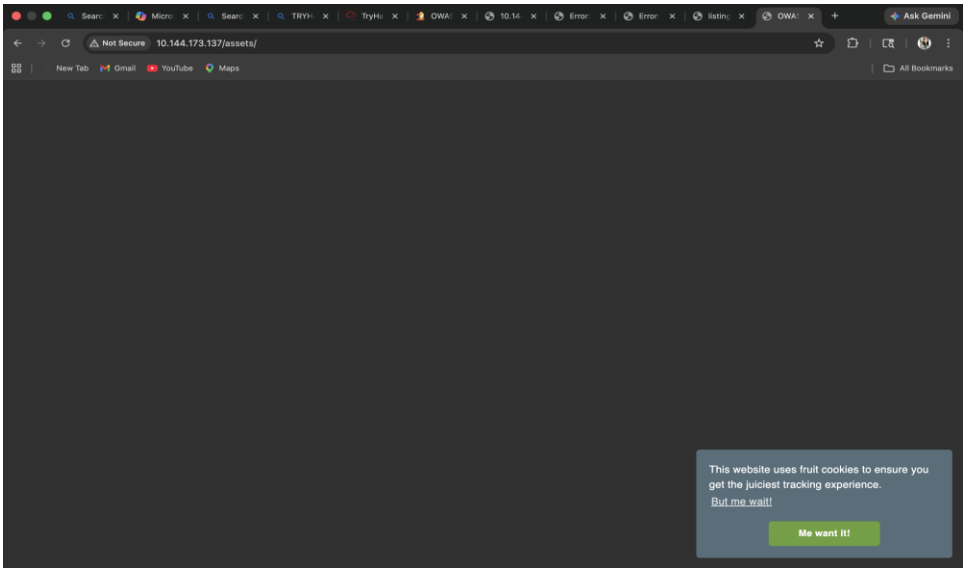
The robots.txt file disclosed the /ftp directory, inadvertently guiding attackers toward sensitive resources.

8.5 /ftp Directory



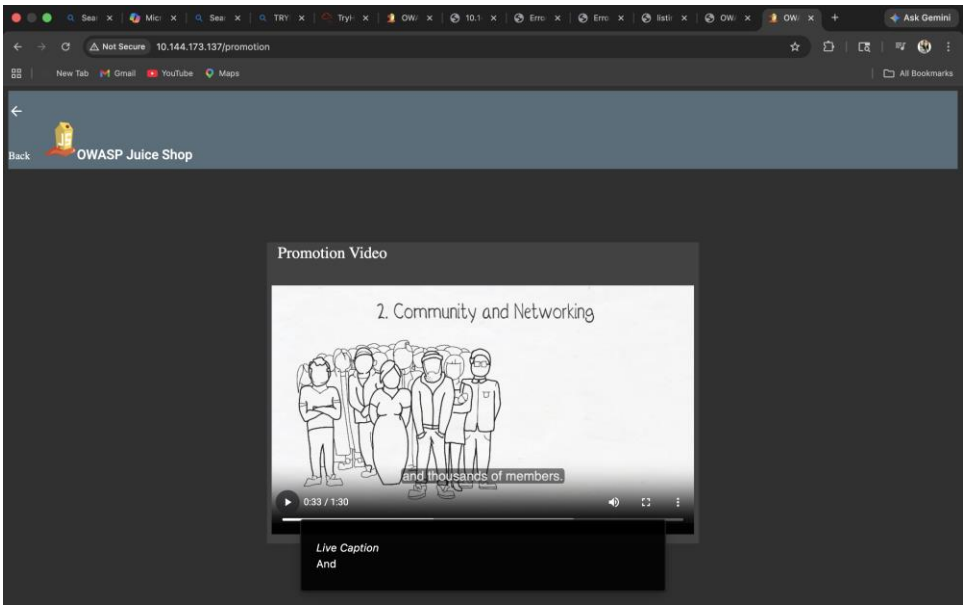
The /ftp directory was publicly accessible and contained multiple sensitive files, including backups, encrypted documents, and configuration files. This represents severe misconfiguration.

8.6 /assets Directory



The /assets directory exposed JavaScript bundles and other static resources, enabling potential reverse engineering of client-side logic.

8.7 /promotion Endpoint



The /promotion endpoint was accessible without authentication, indicating insufficient access control.

9. Vulnerability Findings (OWASP Format)

9.1 Backend Information Disclosure

Verbose error messages from /api and /rest exposed internal file paths and backend logic.

Impact: Enables targeted attacks against backend components. **Severity:** High

9.2 Outdated jQuery Dependency

Fingerprinting identified jQuery 2.2.4, which contains multiple known vulnerabilities.

Impact: Increases susceptibility to client-side attacks such as XSS. **Severity:** High

9.3 Sensitive Directory Disclosure

The robots.txt file revealed the /ftp directory.

Impact: Assists attackers in locating sensitive resources. **Severity:** Medium

9.4 Publicly Accessible /ftp Directory

The /ftp directory contains sensitive files accessible without authentication.

Impact: Simulates real-world cloud storage misconfigurations. **Severity:** High

9.5 Exposed Static Assets

The /assets directory exposed JavaScript bundles.

Impact: Facilitates reverse engineering and client-side exploitation. **Severity:** Medium

9.6 Unrestricted Public Endpoints

Endpoints such as /promotion and /video lack access controls.

Impact: Expands the application's attack surface. **Severity:** Low–Medium

10. Attack Chain Narrative

The vulnerabilities identified form a coherent attack chain:

1. Fingerprinting reveals outdated libraries and backend technologies.
2. Directory enumeration exposes sensitive endpoints.
3. robots.txt discloses the /ftp directory.

4. Backend endpoints leak stack traces and internal logic.
5. Public directories expose sensitive files and client-side code.
6. Combined, these weaknesses enable attackers to map the system, identify exploitable components, and escalate attacks.

This chain demonstrates how layered vulnerabilities can be exploited in sequence to compromise an application.

11. Risk Rating Summary

Vulnerability	Likelihood	Impact	Severity
Backend info disclosure	High	High	Critical
Outdated jQuery	High	High	High
Public /ftp directory	Medium	High	High
robots.txt disclosure	High	Medium	Medium
Exposed assets	Medium	Medium	Medium
Public endpoints	Low	Low	Low

12. Recommendations

High Priority

- Implement proper error handling to suppress stack traces.
- Update outdated JavaScript libraries.
- Restrict or remove public access to the /ftp directory.

Medium Priority

- Minimise sensitive entries in robots.txt.
- Obfuscate or bundle client-side assets.

Low Priority

- Review public endpoints and enforce access controls where appropriate.

13. Conclusion

The assessment revealed a broad spectrum of vulnerabilities across backend, frontend, and deployment layers. These weaknesses collectively demonstrate how misconfigurations, outdated dependencies, and insufficient error handling can converge to create realistic and exploitable attack paths. The findings align with several OWASP Top 10 categories, underscoring systemic gaps in secure development and deployment practices.

Addressing these issues requires a holistic approach that integrates secure coding standards, rigorous dependency management, and robust configuration controls throughout the software development lifecycle. Strengthening these areas will significantly reduce the application's exposure to modern web-based threats and enhance its overall security posture.